

← Sicherheitsprüfung

BANDspirit — Version V.2.0



Alle 13 Sicherheitsprüfungen bestanden

Letzte Prüfung: 23.08.2026

SEC-001

Authentifizierung & Session-Management

✓ Bestanden

📄 Implementierte Massnahmen:

- ✓ JWT Bearer Authentication im Backend (ASP.NET Core); NextAuth.js v4 im Frontend für die Session-Verwaltung
- ✓ Passwort-Hashing mit BCrypt.Net (Standard-WorkFactor 11)
- ✓ Token-basierte Authentifizierung mit JWT (8 Stunden gültig)
- ✓ Automatische Session-Erneuerung im Frontend
- ✓ Sichere Cookie-Konfiguration (httpOnly, secure, sameSite)

SEC-002

Autorisierung (RBAC)

✓ Bestanden

📄 Implementierte Massnahmen:

- ✓ 4-stufiges Rollenmodell (Admin, Lead Link, Fachperson, Sachbearbeiter:in)
- ✓ Ca. 30 granulare Permissions (Organisations- & Administrationsbereich)
- ✓ Server-seitige Prüfung via PermissionAuthorizationHandler (Policy-basiert, aus Permissions.All generiert)
- ✓ Client-seitige UI-Filterung anhand der Berechtigungen
- ✓ Middleware-basierter Routenschutz (JWT + Autorisierung)

SEC-003

Passwort-Sicherheit

✓ Bestanden

📄 Implementierte Massnahmen:

- ✓ Mindestlänge 8 Zeichen
- ✓ Pflicht: Grossbuchstabe, Kleinbuchstabe, Zahl, Sonderzeichen
- ✓ Server-seitige Passwort-Validierung in Signup und Reset
- ✓ Echtzeit-Validierungsanzeige im Frontend

SEC-004 SQL-Injection-Schutz

✓ Bestanden

📄 Implementierte Massnahmen:

- ✓ Entity Framework Core — parametrisierte Queries (kein Raw SQL)
- ✓ Keine Verwendung von FromSqlRaw oder ExecuteSqlRaw
- ✓ Server-seitige Input-Validierung vor DB-Zugriff

SEC-005 XSS-Prävention

✓ Bestanden

📄 Implementierte Massnahmen:

- ✓ React-JSX escaped standardmässig alle Ausgaben
- ✓ Kein Einsatz von dangerouslySetInnerHTML
- ✓ Content-Security-Policy-Header konfigurierbar

SEC-006 API-Sicherheit

✓ Bestanden

📄 Implementierte Massnahmen:

- ✓ Alle Endpunkte erfordern ein gültiges JWT (ausser Auth-Endpoints)
- ✓ [Authorize]-Attribut bzw. RBAC-Policy auf allen geschützten Controllern
- ✓ Generische Fehlermeldungen (keine internen Details an Client)
- ✓ Server-seitige Input-Validierung

SEC-007 Rate-Limiting

✓ Bestanden

📄 Implementierte Massnahmen:

- ✓ Forgot-Password: max. 3 Anfragen pro 5 Minuten pro E-Mail
- ✓ Reset-Password: max. 5 Anfragen pro 5 Minuten pro Token
- ✓ In-Memory Rate-Limiter mit automatischer Bereinigung

SEC-008 Datenbank-Sicherheit

✓ Bestanden

📄 Implementierte Massnahmen:

- ✓ Verschlüsselte Verbindung (SSL/TLS)
- ✓ Zugangsdaten ausschliesslich in Umgebungsvariablen
- ✓ Keine Secrets im Quellcode oder Client-Bundle
- ✓ Connection-Pooling mit Timeout-Konfiguration

SEC-009 Passwort-Reset-Sicherheit

✓ Bestanden

📄 Implementierte Massnahmen:

- ✓ UUID-basierte Token (kryptographisch sicher)
- ✓ Token-Ablauf nach 1 Stunde
- ✓ Einmalverwendung (usedAt Markierung)
- ✓ Alte Tokens werden bei neuem Request invalidiert
- ✓ Keine E-Mail-Enumeration (generische Antwort)

SEC-010 Audit-Trail / Application-Log

✓ Bestanden

📄 Implementierte Massnahmen:

- ✓ Protokollierung aller Login-Vorgänge (erfolgreich + fehlgeschlagen)
- ✓ Protokollierung aller Änderungen an Organisationsdaten (Organisations-Module)
- ✓ Protokollierung aller Änderungen an der Benutzerverwaltung
- ✓ Unveränderlicher Log (nur Lesen, kein Löschen über UI)
- ✓ Filterbar nach Modul, Zeitraum und Benutzer

SEC-011 Secrets-Management

✓ Bestanden

📄 Implementierte Massnahmen:

- ✓ Alle Secrets in .env / Umgebungsvariablen (nicht im Repository)
- ✓ Jwt:Secret (Backend) und NEXTAUTH_SECRET (Frontend) für die JWT-Signierung
- ✓ ConnectionStrings (PostgreSQL) mit Zugangs-Credentials
- ✓ Keine Secrets im Client-Bundle (nur Server-seitig)

SEC-012 Organisation — RBAC-Schutz

✓ Bestanden

📄 Implementierte Massnahmen:

- ✓ 16 granulare Permissions für Organisations-Modul: org:circle:*, org:role:*, org:meeting:*, org:proposal:*, org:objection:*, org:decision:*, org:driver:*
- ✓ Alle OData-Endpunkte (Circles, Roles, Meetings, Proposals, Objections, Drivers) mit RBAC-Policies geschützt
- ✓ JWT-Prüfung in jeder Anfrage — 401 bei fehlendem oder ungültigem Token
- ✓ Rollenbasierte Zuweisung: Admin und Lead Link erhalten vollen Organisations-Zugriff
- ✓ Audit-Logging via AuditMiddleware für alle Organisations-Mutationen (Create, Update, Delete)
- ✓ Input-Validierung in Consent-Workflow (Einwand erfordert Observation, Risk, Domain-Referenz)

- ✓ Cascade-Delete-Schutz: Kreislöschung entfernt abhängige Rollen, Meetings und Drivers konsistent

SEC-013 Vollständige API-Sicherheitsprüfung (V.2.0)

✓ Bestanden

📄 Implementierte Massnahmen:

- ✓ Alle OData- und REST-Endpunkte systematisch geprüft
- ✓ Auth-Schutz: Alle Endpunkte JWT-geschützt — nur /api/auth/* bewusst offen (login, entra-callback, forgot/reset-password, signup)
- ✓ Autorisierung: RBAC-Policies bzw. [Authorize] auf allen geschützten Controllern vorhanden
- ✓ SQL-Injection: 0 Befunde — kein FromSqlRaw/ExecuteSqlRaw im gesamten Projekt (nur EF-Core-LINQ)
- ✓ Error-Handling: Keine internen Fehlerdetails (Exception-Messages, Stack-Traces) in API-Responses
- ✓ Secrets: Konfiguration nur Server-seitig (Umgebungsvariablen / appsettings)
- ✓ Passwort: Der Passwort-Hash wird in keiner API-Response ausgegeben
- ✓ Input-Validierung: Model-Validierung und manuelle Prüfungen durchgängig eingesetzt
- ✓ Empfehlung: Schrittweise Vereinheitlichung der Validierungen (z.B. DataAnnotations / FluentValidation)

📄 Umgesetzte Sicherheitsmaßnahmen (Korrektur 34 & 35)

Korrektur 34 — Sofort-Maßnahmen (SEC-S1 bis S4):

- Passwort-Hashing: Umstellung von sha256 auf BCrypt.Net (Work-Factor 11)
- Sichere Token-Generierung: JWT-Secret mit 64 Zeichen, kryptographisch sichere Zufallstoken
- Startup-Validierung: Prüfung auf Placeholder-Secrets, Anwendung startet nicht mit unsicheren Defaults
- Passwort-Invariante: User.Password mit [JsonIgnore], UsersController gibt nur UserDto ohne Passwortfeld zurück

Korrektur 35 — Kurzfristige Maßnahmen (SEC-M5 bis M8 + DSGVO-M1):

- API-Audit-Logging: Alle API-Zugriffe (Erfolg/Fehler) werden in AppLog persistiert
- Rate-Limiting: 100 Requests/min pro IP (Login/API), 5 Requests/min für Passwort-Reset
- Security-Header: X-Content-Type-Options, X-Frame-Options, CSP via SecurityHeadersMiddleware
- Frontend-Fehlerbehandlung: Sichere Fehlerausgabe ohne Stack-Traces in Produktion

- Log-Minimierung (DSGVO): Details-Feld JSON statt Freitext, keine sensiblen Daten in Logs

Stand: 23.08.2026 — Alle 13 Sicherheitsprüfungen bestanden nach Umsetzung der Sofort- und kurzfristigen Maßnahmen.